SNOWBE ONLINE SECURITY PLAN

Group Member Names:
Meshia Reed

Version 1
Date: 23 November 2025

Table of Contents

Section 1: Introduction *2*
Section 2: Scope *2*
Section 3: Definitions *2*
Section 4: Roles & Responsibilities *3*
Section 5: Statement of Policies, Standards and Procedures *4*
Policies **4**
Standards and Procedures **5**
Section 6: Exceptions/Exemptions *5*
Section 7: Version History Table *6*
Citations *6*

Section 1: Introduction

This Security Plan was created to establish an organized approach for the protection of SnowBe's data, information systems, and technology assets. The Plan outlines roles, policies, and procedures needed to guarantee the confidentiality, integrity, and availability of company and customer data.

Section 2: Scope

This Security Plan applies to all SnowBe staff, contractors, and third parties with company systems or data access. It includes all devices, applications, networks, and data throughout SnowBe's offices, storefronts, remote environments, and cloud platforms.

Section 3: Definitions

Chief Information Officer (CIO)
Senior executive in charge of the management and protection of the company's information and technology systems.

Chief Information Security Officer (CISO)
Oversees access control strategy and policies for compliance and connects access control with all security policies.

Cloud Platforms
Online services that hold and process data without local servers.

Compliance Officer
This individual ensures the company complies with laws, regulations, and internal rules.

Confidentiality, Integrity, and Availability (CIA Triad)
The three work together to ensure information is secure, accurate, and accessible.

Data Custodian
This individual handles the technical aspects and safeguards of data, such as storage, access, and backups.

Firewall
A system used to prevent unauthorized access in and out of a private network.

HIPAA
This is a US law that protects patient health information (PHI) from unauthorized disclosure.

Information Security Officer (ISO)

This individual guides the creation and enforcement of cybersecurity policies and procedures in the company.

Monitoring Tools
This is software utilized to track issues, suspicious activity, and failures in a system or network.

Network Infrastructure
Hardware and software that enable network connectivity, operations, and communication.

Patch
Fixes security bugs or flaws in a system through a software update.

PCI DSS
Security standards for companies handling credit card information for the prevention of fraud and data breaches.

Physical Access Controls
Tangible tools like ID badges, door locks, and keycards limit physical access to certain areas.

Surveillance
Physical space monitoring through the use of cameras or sensors for enhanced security.

System Configuration
Determines how a computer or a server functions and who has access to it based on settings and setup.

Third Parties
Companies like vendors or contractors and external people with company system or data access.

Virtual Private Network (VPN)
Helps protect data from outside threats by securely connecting to the company's network over the internet.

Section 4: Roles & Responsibilities

Chief Information Officer (CIO) - Provides executive oversight for the entire information security program.

Chief Information Security Officer (CISO) – Develops encryption policies and standards for all sensitive data.

Compliance Officer - Ensures that the organization adheres to all applicable laws, regulations such as HIPAA and PCI DSS, and internal policies.

Data Custodian - Is responsible for the day-to-day maintenance and protection of organizational data.

Department Heads - Are accountable for ensuring their teams comply with security policies.

Information Security Officer (ISO) - Leads the development and implementation of cybersecurity strategies and policies.

Network Administrator - Manages network infrastructure components such as firewalls, virtual private networks, and monitoring tools.

Physical Security Officer - Oversees physical access controls including badge systems and surveillance.

System Administrator - Maintains servers and critical IT infrastructure, applies necessary patches, manages system configurations, and enforces user access permissions.

Users (All Staff and Faculty) - Are responsible for adhering to security policies, properly using organizational systems, and promptly reporting any suspicious activities or security incidents.

Section 5: Statement of Policies, Standards and Procedures

Policies

1. System Development Life Cycle (SDLC) Policy

This policy provides a structured, secure, and repeatable process for developing, testing, deploying, and maintaining information systems for SnowBe. It establishes phases within the system lifecycle aligned with NIST SP 800-160 and the Risk Management Framework (RMF) which, before any system or software release, specify requirements to be documented and security validation to be performed and approved by the Chief Information Security Officer (CISO). Any future changes to the system and/or software must comply with the Change Control Management Policy.

2. Patch Management Policy

This policy maintains the security of all SnowBe systems, applications, and network devices by implementing timely installation, testing, and documentation of security patches and updates. It describes a timeline for prioritization of patch installation, testing of updates, documentation standards, and procedures for ongoing maintenance to mitigate known vulnerabilities and maintain correctness of the operating system and/or software platforms being managed by SnowBe.

3. Security Maturity Policy

This policy defines SnowBe's process for measuring and maturing its cybersecurity posture through continuous evaluation, planning, and remediation. This Security Maturity Policy uses a five-level cybersecurity maturity model; creates KPIs to measure effectiveness and incorporates key findings into SnowBe's security planning and education in order to continuously align its cybersecurity program to the Cybersecurity Framework created by NIST (CSF), RMF, and its business objectives.

Standards and Procedures

Section 6: Exceptions/Exemptions

Exceptions

An exception is required for each device that does not meet minimum security standards. This process and form are also required where Snowbe, regulatory, legal or contract requirements related to information security cannot be met. Exceptions will be granted for a maximum of one year.

Resource Proprietors and Service Providers: If your environments or configurations do not comply with the Minimum-Security Standards listed above, you must request an exception using the form linked below. This process can also be used to request an exception from other Snowbe information security requirements.

Personally Owned Devices: Individuals whose personal device or configurations do not comply with Minimum-Security Standards may use this form to submit an exception request to allow the device to connect to (or remain on) the Snowbe network. This category only applies to personal devices not used for Snowbe business purposes and that do not contain organization information.

Annual review is required for exception renewal. Please be aware that all exceptions are temporary, and systems must ultimately be brought into compliance.

Non-compliant systems that pose significant risk to Snowbe resources may face removal from the Snowbe network and/or other take-down action regardless of exception status.

Exemptions

This exemption category applies only to personal devices not used for Snowbe business purposes and that do not contain organizational information.

Temporary Nature: All exceptions are temporary and require annual review for renewal; systems are expected to eventually be brought into compliance.

Consequences of Non-Compliance: Non-compliant systems posing a significant risk to Snowbe

resources may be removed from the network or face other take-down actions, regardless of their exception status.

Section 7: Version History Table

Version	Date	Description
1.0 Meshia Reed	11/23/25	4.5 Final Submission

Citations

Drake State IS Plan - Purpose/Introduction
Illinois Wesleyan IS Policy - Purpose/Introduction
Michigan Tech IS Plan - Scope
California State IS Plan - Scope
Motlow State IS Plan - Definitions
Nevada State IS Plan - Roles & Responsibilities
Carnegie Mellon IS Plan – Exceptions/Exemptions
Howard University IS Plan – Enforcement